IS Audit & Control

Abdul-Rahman Mahmood
Assistant Professor, Computer Science, FAST-NU

abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

Auditing Routers Switches, and Firewalls

Part II

General Network Equipment Audit Steps

- **6. Ensure that appropriate password controls are used.**
  - Ensure complex passwords are used
  - MD5 hashes
  - Password changed with appropriate periodicity
  - Passwords used for privileged modes of operation should never be the same as any other password used on the device.
  - same password isn't shared on network devices.
  - Passwords shared on the WAN should not be used on the LAN.

General Network Equipment Audit Steps

- **7. Verify that secure management protocols are used where possible.**
  - Telnet, SNMP V1 & SNMP V2 -> plaintext passwords
  - Discuss management procedures with the network administrator.
  - Review the configuration of the network device. Ensure that policies and procedures exist to manage routers, switches, and firewalls as securely as possible.
  - Secure Shell (SSH) Protocol, another secure management protocol, or an out-of-band management system should be used for remote administration.

General Network Equipment Audit Steps

- **8. Ensure that current backups exist for configuration files.**
- **9. Verify that logging is enabled and sent to a centralized system.**
  - Ensure that appropriate log levels are used. Log levels range from 0 to 7 on Cisco equipment.
  - Log level 0 = log only emergencies (unusable system)
  - Log level 7 = debug-level logging.
  - SNMP traps are identified by the following:

```
snmp-server host [log host] [version] [community string] [trap-type]
snmp-server enable traps [trap-type]
```

General Network Equipment Audit Steps

- An SNMP trap is a type of SNMP protocol data unit (PDU). Unlike other PDU types, with an SNMP trap, an agent can send an unrequested message to the manager to notify about an important event.
- There are five standard SNMP traps that are supported by Data ONTAP: coldStart, warmStart, linkDown, linkUp, and authenticationFailure. Built-in traps are predefined in Data ONTAP and are automatically sent to the network management stations on the traphost list if an event occurs.

General Network Equipment Audit Steps

- Why is it called SNMP trap?
  - It only sends out SNMP messages when prompted by a request from the SNMP manager. However, if the agent detects an emergency event on the device that it is monitoring, it will send out a warning message to the manager without waiting to be polled for data. This emergency message is called a trap.

General Network Equipment Audit Steps

- **10. Evaluate use of Network Time Protocol (NTP).**
  - standardize all clocks to a single time zone.
  - The following config file indicates that NTP is enabled. Key option is used with authentication.
  - ntp server <ip address> key <key>
- **11. Verify that a banner is configured to make all connecting users aware of the company's policy for use and monitoring.**
- Confirm that the motd or login banner does not disclose any information about the company or network device.
- This information should be reserved for the exec banner after a successful login.
- CISCO: **banner motd** or the **banner login**.

General Network Equipment Audit Steps

- **12. Ensure that access controls are applied to the console port.**
  - Verify that physical access to the console port is protected.
  - Verify that logical access to the console port is password-protected.

show running-config

- Below is an example of router output from the show running-config command:

```
2509#show running-config
Building configuration...
Current configuration : 655 bytes
!
version 12.2
.
.
line con 0
line 1 8
line aux 0
line vty 0 4
!
end
```

Configure Passwords on the Line

```
configure terminal
Enter configuration commands, one per line.  End with
CNTL/Z.
router(config)#line con 0
router(config-line)#
Configure the password, and enable password checking at
login.
router(config-line)#password letmein
router(config-line)#login
Exit configuration mode.
router(config-line)#end
router#
%SYS-5-CONFIG_I: Configured from console by console
Note: Do not save configuration changes to line con 0
until your ability to log in has been verified.
Note: Under the line console configuration, login is a
required configuration command to enable password checking
at login. Console authentication requires both the
password and the login commands to work.
```

Verify the Configuration

```
router#show running-config
Building configuration...
...

!
line con 0
password letmein
login
line 1 8
line aux 0
line vty 0 4
!
end
```

Configure Local User-Specific Passwords

```
router#configure terminal
Enter configuration commands, one per line.  End
with CNTL/Z.
router(config)#username russ password montecito
router(config)#username cindy password belgium
router(config)#username mike password rottweiler
```

Switch to line configuration mode, using the following commands. Notice that the prompt changes to reflect the current mode.

```
router(config)#line vty 0 4
router(config-line)#
Configure password checking at login.
router(config-line)#login local
Exit configuration mode.
router(config-line)#end
router#
%SYS-5-CONFIG_I: Configured from console by console
```

Verify the Configuration

```
router#show running-config
Building configuration...
!
!
username russ password 0 montecito
username cindy password 0 belgium
username mike password 0 rottweiler
!
line con 0
line 1 8
line aux 0
line vty 0 4
 login local
!
end
```

General Network Equipment Audit Steps

- **13. Ensure that all network equipment is stored in a secure location.**
- **14. Ensure that a standard naming convention is used for all devices.**

General Network Equipment Audit Steps

- **15. Verify that standard, documented processes exist for building network devices.**
  - Documented processes provide repeatability of secure designs and higher quality workmanship, helping to prevent common mistakes that might lead to a service disruption or network compromise.
  - **How**
  - Discuss documented policies and procedures for building network equipment with the network administrator. If possible, verify using a recent build that the process was followed.

General Network Equipment Audit Steps

- Covered in class

Checklist for Auditing Network Equipment

❑	1. Review controls around developing and maintaining configurations.
❑	2. Ensure that appropriate controls are in place for any vulnerabilities associated with the current software version. These controls might include software updates, configuration changes, or other compensating controls.
❑	3. Verify that all unnecessary services are disabled.
❑	4. Ensure that good SNMP management practices are followed.
❑	5. Review and evaluate procedures for creating user accounts and ensuring that accounts are created only when there is a legitimate business need. Also review and evaluate processes for ensuring that accounts are removed or disabled in a timely fashion in the event of termination or job change.
❑	6. Ensure that appropriate password controls are used.
❑	7. Verify that secure management protocols are used where possible.
❑	8. Ensure that current backups exist for configuration files if applicable.
❑	9. Verify that logging is enabled and sent to a centralized system.
❑	10. Evaluate use of the Network Time Protocol (NTP).
❑	11. Verify that a banner is configured to make all connecting users aware of the company's policy for use and monitoring.
❑	12. Ensure that access controls are applied to the console port.
❑	13. Ensure that all network equipment is stored in a secure location.
❑	14. Ensure that a standard naming convention is used for all devices.
❑	15. Verify that standard, documented processes exist for building network devices.

Auditing Layer 2 Devices: Additional Controls for Switches

- (Refer to book for details on how to achieve)

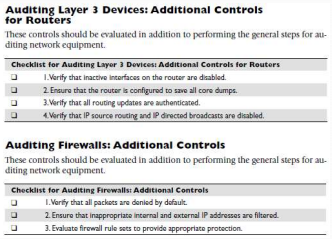
Auditing Layer 2 Devices: Additional Controls for Switches

These controls should be evaluated in addition to performing the general steps for auditing network equipment.

Checklist for Auditing Layer 2 Devices: Additional Controls for Switches

❑	1. Verify that administrators avoid using VLAN 1.
❑	2. Evaluate the use of trunk autonegotiation.
❑	3. Verify that Spanning-Tree Protocol attack mitigation is enabled (BPDU Guard, Root Guard).
❑	4. Evaluate the use of VLANs on the network.
❑	5. Disable all unused ports, and put them in an unused VLAN.
❑	6. Evaluate use of the VTP in the environment.
❑	7. Verify that thresholds exist that limit broadcast/multicast traffic on ports.

Auditing Layer 3 Devices: Additional Controls for Routers



Auditing Layer 3 Devices: Additional Controls for Routers

These controls should be evaluated in addition to performing the general steps for auditing network equipment.

Checklist for Auditing Layer 3 Devices: Additional Controls for Routers
❑ 1. Verify that inactive interfaces on the router are disabled.
❑ 2. Ensure that the router is configured to save all core dumps.
❑ 3. Verify that all routing updates are authenticated.
❑ 4. Verify that IP source routing and IP directed broadcasts are disabled.

Auditing Firewalls: Additional Controls

These controls should be evaluated in addition to performing the general steps for auditing network equipment.

Checklist for Auditing Firewalls: Additional Controls
❑ 1. Verify that all packets are denied by default.
❑ 2. Ensure that inappropriate internal and external IP addresses are filtered.
❑ 3. Evaluate firewall rule sets to provide appropriate protection.

(Refer to book for details on how to achieve)